

استخدام معيار الممارسات الجيدة في أمن المعلومات SGP

وظيفة مقرر أمن نظم المعلومات BIS601 للفصل S25

بإشراف الدكتور: محمد الجنيدي

Class : 2

Salam_158996

Salam jamal aldeen

Salam_158996@svuonline.org

Sereen_152552

Sereen alsayed

Sereen_152552@svuonline.org

Mohannad_192707

Mohannad alsaker

Mohannad_192707@svuonline.org

Leelaas_161626

Leelaas sreyo

Leelaas_161626@svuonline.org

مراحل توظيف SGP للامتثال ISO/IEC 27001

- ما هو SGP؟

اختصاراً لـ "Security Governance Pathway"، وهو إطار منهجي يساعد المؤسسات على تطبيق متطلبات الأيزو 27001 بشكل تدريجي ومنظم.

- لماذا نستخدمه؟

لأن الأيزو 20071 يصف "ماذا" نعمل، لكن SGP يصف "كيف" ننفذ ونراقب الامتثال.

- العلاقة بينهما:

SGP يترجم ضوابط الأيزو (الملحق A) إلى مشاريع ومهام وجداول زمنية.

- مخرجات التوظيف الناجح:

الحصول على الشهادة، تقليل المخاطر، تحسين الحوكمة الأمنية



المرحلة الاولى – تحديد النطاق وتحليل السياق (Context & Scope)

أول خطوة في SGP هي فهم بيئة المؤسسة وتحديد حدود نظام إدارة أمن المعلومات (ISMS) قبل تطبيق أي ضوابط.

العنصر	الشرح
تحديد نطاق ISMS	الأقسام، الأنظمة، المواقع، البيانات المشمولة بالامتثال
تحليل السياق الداخلي	الهيكل التنظيمي، السياسات الحالية، الثقافة الأمنية
تحليل السياق الخارجي	المتطلبات القانونية، عقود العملاء، التهديدات الخارجية
تحديد الأطراف المعنية	الموظفون، العملاء، الموردون، الجهات الرقابية
مخرجات SGP في هذه المرحلة	تقرير النطاق وسجل الأطراف المعنية

المرحلة الثانية – تقييم الفجوات (Gap Analysis)

نقارن بين الوضع الحالي للأمن السيبراني ومتطلبات ISO/IEC 27001 لنعرف أين نحن وأين يجب أن نكون.

العنصر	الشرح
اختيار مرجع المقارنة	ضوابط الملحق A (التحكم 5 حتى 8) وأهداف الرقابة
جمع الأدلة الحالية	سياسات، إجراءات، محاضر، تكوينات تقنية
تقييم النضج	كل ضابط يُقيّم من 0 (غير موجود) إلى 5 (محسن)
حساب الجواب	الفرق بين النضج الحالي والمطلوب (مثلا 3 من 5)
توثيق النتائج	مصفوفة فجوات SGP: كل ضابط وسبب الفجوة وأثرها

المرحلة الثالثة – تصميم خطة المعالجة (Treatment Plan)

بعد معرفة الفجوات، نضع خطة عمل لسدها مع تحديد المسؤوليات والموارد والمهل الزمنية، وهنا يظهر الدورة التنفيذي لSGP.

العنصر	الشرح
أولوية المعالجة	حسب تقييم المخاطر: فجوات حرجة أولاً
أنواع المعالجة	وضع سياسة جديدة، تعديل إجراء، شراء أداة تقنية، تدريب
تعيين مالك الضابط	شخص مسؤول عن تنفيذ كل ضابط ناقص
الجدول الزمني	مراحل SGP: قصيرة المدى (شهر)، متوسطة (3 أشهر)، طويلة
مخرجات SGP	خطة معالجة المخاطر جاهزة للمراجعة

المرحلة الرابعة – التوثيق والقياس (Documentation & KPIs)

الامتثال للأيزو 20071 يعني توثيق كل شيء، وقياس فعالية الضوابط باستمرار. هنا SGP يوفر قوالب جاهزة ومؤشرات أداء.

العنصر	الشرح
وثائق إلزامية	نطاق ISMS، سياسة أمن المعلومات، بيان قابلية التطبيق (SoA)
سجلات مطلوبة	سجلات التدريب، الحوادث، مراجعات الإدارة، التقييمات
مؤشرات SGP المقترحة	إنجاز خطة المعالجة، عدد الفجوات المعلقة، متوسط وقت سد فجوة
تكرار القياس	شهريا للتقدم، ربع سنوي للفعالية
أداة التوثيق	يمكن استخدام Excel، او SharePoint، أو GRC tool

المرحلة الخامسة – المراجعة الداخلية والاستعداد للشهادة

آخر مرحلة في SGP قبل التدقيق الخارجي: نتحقق من أن كل ما طبقناه يعمل فعلا ولا يوجد فجوات متبقية.

العنصر	الشرح
المراجعة الداخلية	فريق مستقل يدقق على كل ضوابط الأيزو المطبقة
معالجة نقاط عدم المطابقة	أي NC يتم إغلاقه قبل طلب التدقيق الخارجي
مراجعة الإدارة	الإدارة العليا تراجع أداء ISMS بناء على تقارير SGP
اختيار جهة مانحة للشهادة	مثل SGS، DNV، BSI وتجهيز ملف الطلب
الاستعداد للتدقيق	محاكاة جلسات التدقيق باستخدام SGP كدليل إثبات

استخدام المعيار SGP في تشكيل بنية فريق أمن سبراني وتوزيع المسؤوليات فيه

أهمية فريق أمن المعلومات وفق SGP

- يُعد معيار SGP إطاراً لأفضل الممارسات في أمن المعلومات
- يمكن الاسترشاد به في تصميم هيكل فريق الأمن
- يدعم التوازن بين التوجه الاستراتيجي والمهام التشغيلية
- يعزز مفهوم "ملكية المخاطر" داخل وحدات العمل



أهمية وجود فريق أمن المعلومات

- حماية بيانات وأنظمة المؤسسة
- دعم استمرارية الأعمال وتقليل التوقف
- المساعدة في الالتزام بالمعايير مثل ISO 27001
- التعامل مع المخاطر بشكل استباقي
- تعزيز ثقة العملاء والجهات المتعاونة
- دمج الأمن ضمن استراتيجية المؤسسة



نماذج هيكلية فريق الأمن:

النموذج الموزع:

- فهم أدق لاحتياجات الأقسام
- استجابة أسرع للحوادث

النموذج المركزي:

- سياسات موحدة وحوكمة واضحة
- مناسب للمؤسسات الصغيرة

ملاحظة: يختلف اختيار النموذج حسب حجم المؤسسة وطبيعة عملها

الأدوار الرئيسية في فريق الأمن

CISO: وضع الاستراتيجية وإدارة المخاطر والميزانية

- محلل أمن: مراقبة الأنظمة وتحليل التنبيهات

- مهندس أمن: تصميم وتنفيذ الحلول الأمنية

- مستجيب للحوادث: التحقيق في

الحوادث واحتواء الأضرار

- مسؤول الحوكمة والامتثال (GRC): متابعة السياسات وضمان الالتزام بالمعايير



توزيع المسؤوليات وهيكل الفريق

توزيع المسؤوليات:

- CISO: قرارات استراتيجية وإدارة المخاطر
- محلل: مراقبة وتحليل التهديدات
- مهندس: تنفيذ الضوابط الأمنية
- مستجيب: التعامل مع الحوادث والتنسيق مع التعافي
- GRC: مراجعة السياسات والامتثال

حسب حجم المؤسسة:

كبيرة: فرق متخصصة (SOC، هندسة، امتثال) + بنك أو شركة اتصالات

متوسطة: فريق أساسي (CISO + مهندس + محلل) + شركة تجارة إلكترونية إقليمية

صغيرة: مدير أمن + تعهيد (Virtual CISO) + مثال شركة ناشئة لخدمات برمجية

الاستعانة بمصادر خارجية + مثال

التعهد (Outsourcing):

- يمكن تعهيد: ▪ مراقبة الأمن (SOC) ▪ اختبار الاختراق
- يجب الاحتفاظ ب: ▪ القرارات الاستراتيجية ▪ التحكم في الأنظمة الحساسة
- النموذج الأفضل: هجين (فريق داخلي للحوكمة والرقابة + مورد خارجي (MDR) للعمليات التشغيلية).
- شروط النجاح : تحديد المسؤوليات في SLA بوضوح , تقييم المخاطر السابقة , حق المؤسسة في التدقيق والمتابعة

مثال (مستشفى):

طبيعة العمل:

تعليم طبي، عمليات جراحية، مئات المرضى يومياً، جميع الأجهزة الطبية متصلة بالشبكة.

الفريق المقترح :

- CISO واحد (بدوام كامل)
- محللو أمن (4 يعملون بورديات تغطي 24 ساعة)
- مهندسا أمن (2)
- مستجيبو حوادث (3)
- مدير امتثال (1)

أدوات:

- SIEM لجمع السجلات
- حل لمنع البرمجيات الخبيثة خاص بالأجهزة الطبية
- نظام نسخ احتياطي سريع للملفات الطبية
- تشفير بيانات المرضى

استخدام المعيار SGP للتحقق من كفاية وملائمة الحلول الأمنية المتبعة في مؤسسة معينة

أهمية معيار SGP في مؤسسة الطاقة

مع التغيرات المستمرة لتهديدات الأمن، زادت الحاجة في المؤسسات إلى وجود أطر حماية تساعد في مواجهة الهجمات والاستجابة السريعة للمخاطر المتزايدة.

وفي مؤسسة الطاقة مثلاً، يعتبر أمن المعلومات وأمن التحكم الصناعي (OT) أمراً حيوياً لضمان استمرارية الإمداد بالطاقة، وحماية البنية التحتية الحرجة.

ومن بين العديد من أطر الحماية يُعد معيار SGP إطار عملي مرن يساعد على التحقق من أن الحلول الأمنية المطبقة تغطي المخاطر بشكل فعال وتتناسب مع طبيعة العمليات الصناعية الحساسة وحجم المؤسسة، كما أنه يساعد على ضمان حوكمة وعمليات أمنية فعالة، والحفاظ على الامتثال، وحماية أصول معلوماتها.

الحلول الأمنية ومطابقتها مع ضوابط SGP

الحلول التقنية :

- استخدام أنظمة كشف التسلل (IDS) المخصصة للشبكات الصناعية، وتشفير البيانات الحساسة. للتأكد من أن مراقبة حركة البيانات كافية لرصد الهجمات المتطورة، وهذا يتطابق مع **Network Security** في **SGP**

- تشفير البيانات **Cryptography**: من أجل التحقق من ملائمة خوارزميات التشفير لحجم البيانات وسرعة المعالجة.

- إدارة الهوية والوصول **Identity and Access Management**: لضمان التحكم في الوصول ومنع الدخول غير المصرح به للأنظمة الحساسة.

- تقييم الموردين لأجهزة التحكم: تجنباً لاختراق الأنظمة عبر أجهزة طرف ثالث.

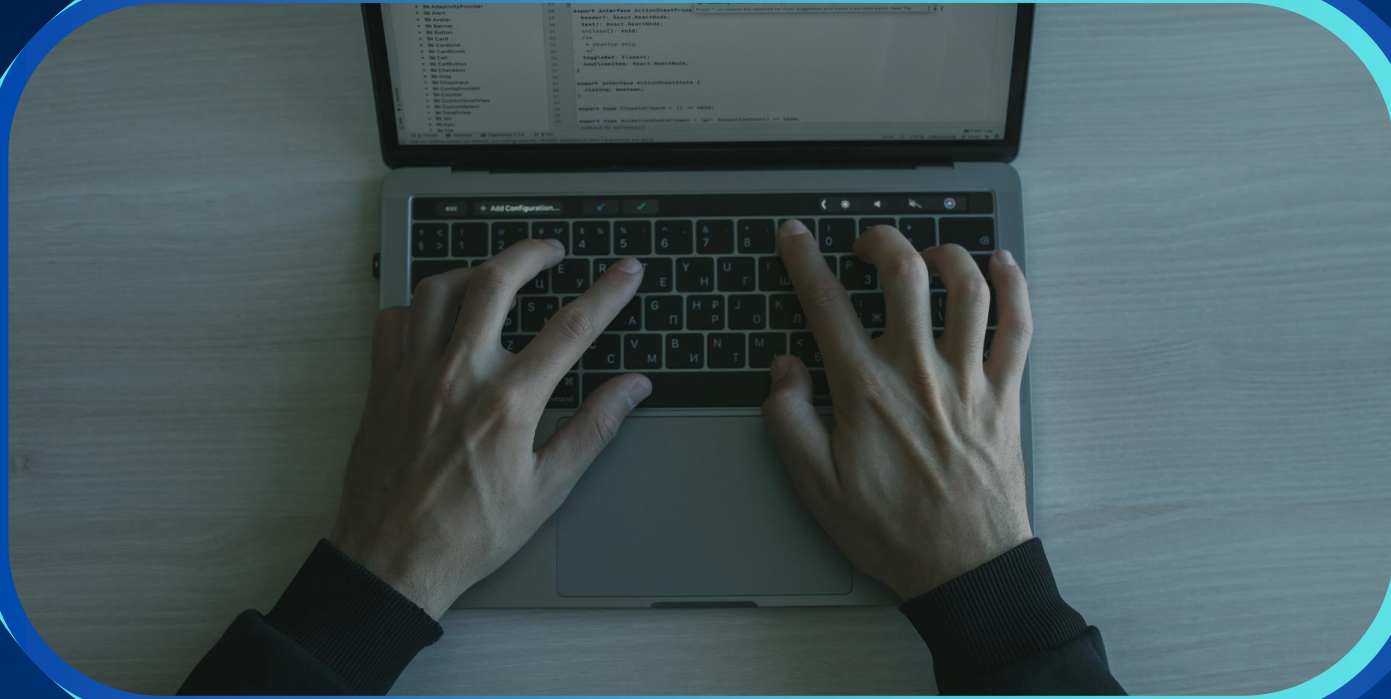
. **الحلول الإدارية**: سياسات صارمة للوصول وبروتوكولات الاستجابة للطوارئ **Security Governance & Operations**.



التحقق من كفاية الحلول الأمنية باستخدام SGP

يتم إجراء Gap Analysis من خلال مقارنة الضوابط الحالية مع ممارسات معيار SGP وهذا قد ينتج عنه ضوابط مفقودة، ضعيفة أو زائدة، ففي مؤسسة الطاقة يتم عمل تغطية كاملة لمخاطر أنظمة التحكم الصناعي بالإضافة إلى وجود استراتيجية حوكمة أمنية مدعومة من الإدارة العليا للمؤسسة، مع تطبيق ضوابط كافية لإدارة المخاطر الناشئة على سلسلة التوريد أو الأجهزة الميدانية.

وبالتالي سيتم اكتشاف أي فجوات في المراقبة المستمرة وتعزيزها في مواجهة أي تهديد حالي ومستقبلي دون التأثير على توافر الخدمة.





التحقق من ملائمة الحلول الأمنية باستخدام SGP

في مؤسسة الطاقة لا يتم تطبيق حلول تقليدية على أنظمة التحكم، بل يتم تخصيص ضوابط حسب بيئة OT. بالإضافة إلى برامج التدريب للموظفين التي تتناسب مع الثقافة التشغيلية والسلامة ويعد استخدام أدوات SGP مثل Benchmark من العوامل المساعدة في قياس الملاءمة وتقديم ضمان للإدارة بأن الحلول مناسبة وغير مبالغ فيها.

الفوائد والتحديات من تطبيق SGP في المؤسسة

- الفوائد:

- الاستجابة السريعة للتهديدات المتزايدة دون انقطاع في إمداد الطاقة.
- ربط الأمن مباشرة بأهداف الأعمال (السلامة، الموثوقية، وحماية السمعة).
- إدارة سلاسل التوريد بنهج قائم على المخاطر لأمن المعلومات
- ضمان الامتثال التنظيمي وتقديم تقارير موثوقة للجهات المعنية.
- رفع مستوى الوعي والتعليم الأمني للموظفين
- تحليل مدى نجاح ضوابط الحماية من المعلومات عبر الشركة بأكملها.

- التحديات :

الحاجة إلى تكييف الممارسات مع بيئة OT/IT المختلطة، وتدريب الفرق الفنية، والحصول على الإصدارات المحدثة من SGP
نتيجةً لذلك سيكون لدى المؤسسة نظام أمني مستدام يحمي العمليات الحرجة ويحسن الموقع التنافسي.

تعزيز الأمن المستدام في المؤسسة وفق معيار SGP

- التقييم الذاتي: عن طريق أداة ISF Benchmark يمكن إجراء تدقيق دوري على كافة ضوابط الأمن في بيئتي الـ (IT) والـ (OT)
- معالجة الفجوات: سد الثغرات المكتشفة في الأنظمة الصناعية الحساسة حسب أولويات المخاطر التجارية والتشغيلية.
- التحديث الدوري: الالتزام بالحصول على أحدث إصدارات معيار SGP لضمان مواكبة التهديدات الناشئة التي تستهدف قطاع الطاقة.

وأخيراً يُعد الالتزام بمعيار SGP استراتيجية جيدة، تمكن المؤسسة من بناء وضع أمني شامل ومرن يتطور مع تزايد مشهد التهديدات.